PERMANEÇO · PERGUNTAS TÉCNICAS

Funcionalidades e IA em respostas curtas

Cola rápida para a banca. Cada resposta reflete o que está implementado no repositório github.com/KazuyaGIH/permaneco-mvp.

Funcionalidades

O que é a Permaneço?
Uma mentora de IA que conversa com calouros do EAD, lembra da rotina e dos objetivos de cada um e monta um plano de estudos, carreira e finanças que cabe no tempo real do aluno.

O que o aluno faz no app?
Aceita o consentimento, conversa no chat e encerra a conversa. Depois vê o “Meu Plano” e a lista do que a IA lembra, e pode apagar qualquer memória.

Como o plano é gerado?
Ao fim da conversa, a IA gera o plano em JSON, que o backend valida. As horas de estudo nunca passam das horas livres que o aluno declarou, e carreira e auxílios só citam itens que existem na base da instituição.

A IA pode mudar o plano sozinha?
Não. Ela cria uma proposta de mudança, e o plano só ganha uma nova versão depois que o aluno aceita.

O que tutor e admin veem?
O tutor vê só os alunos atribuídos a ele. O admin vê só contas e papéis, sem o conteúdo das conversas.

Como a IA funciona

Qual modelo vocês usam?
Gemini 3.6 Flash, no plano gratuito. Quando a cota acaba (erro 429), o app troca sozinho para o Gemini 3.5 Flash-Lite. O provider é uma interface: dá para trocar por OpenAI, e os testes usam um modelo falso.

Como a resposta aparece em tempo real?
Por streaming (SSE): o texto chega aos poucos e passa por um filtro antes de aparecer na tela.

O que a IA recebe a cada mensagem?
O system prompt e blocos de contexto com perfil, memórias, resumo da última conversa, próximos passos, plano atual e o histórico recente da conversa.

Ela usa ferramentas?
Sim, seis: buscar na base, atualizar próximos passos, propor mudança no plano, reagendar check-in, sinalizar preocupação e encerrar check-in. Cada uma tem schema estrito, e são no máximo 3 chamadas por resposta.

Como evitam que ela invente informação?
Carreira e auxílios vêm só da base curada da instituição, por busca full-text no Postgres. O plano é rejeitado se citar um item que não existe, e o prompt manda a IA dizer que não sabe e indicar o canal oficial.

Como funciona a memória?
Ao encerrar a conversa, um modelo rápido extrai fatos curtos sobre o aluno, mas só se ele aceitou a memória. Ordens para a IA, dados pessoais e dados sensíveis são descartados, e fatos repetidos são juntados.

E se o aluno estiver em risco?
A IA acolhe, indica o CVV (188) e o SAMU (192) e chama a ferramenta que registra um alerta para a equipe humana. O fluxo completo do tutor está no roadmap.

Como controlam o custo?
Cada aluno tem um limite diário de tokens (padrão de 25 mil). Ao atingir, recebe uma mensagem gentil para continuar no dia seguinte.

Segurança da IA

Qual é o protocolo contra prompt injection?
Defesa em camadas: o que vem do aluno ou do banco entra no prompt como dado, nunca como instrução, e um token canário secreto detecta vazamento do prompt. Além disso, as ferramentas só aceitam argumentos validados, e a saída é filtrada antes de chegar à tela.

Como o texto do aluno vira "dado"?
Todo contexto vai em blocos marcados (ex.: <memorias>), com as tags escapadas para ninguém conseguir fechar o bloco. O system prompt manda ignorar qualquer instrução escrita dentro deles.

E se tentarem extrair o system prompt?
O prompt carrega um código secreto aleatório (canário). Se ele aparecer na resposta, a resposta é trocada por uma recusa e o vazamento é registrado como evento de segurança.

Vocês detectam tentativas de injeção?
Sim. Uma heurística reconhece padrões como "ignore as instruções" e "system:" e registra um evento de segurança para auditoria.

E se tentarem "envenenar" a memória?
Os candidatos à memória que parecem ordens para a IA (ex.: "a partir de agora...") são descartados antes de serem salvos.

A IA pode mandar links maliciosos?
Não. A saída tem HTML, imagens e links fora de uma lista de domínios permitidos removidos, com limite de 4.000 caracteres.

Como protegem dados pessoais?
Antes de salvar e de enviar ao modelo, o backend remove CPF, RG, cartão (com checagem de Luhn), conta bancária, e-mail e telefone. Também retira caracteres invisíveis, que podem esconder instruções.

Os dados ficam criptografados?
Sim. Mensagens, memórias, resumos, planos e propostas são gravados com AES-256-GCM, com chave identificada por id para permitir rotação.

E o acesso à conta?
Senha com Argon2, sessão no servidor, proteção CSRF, bloqueio após 5 tentativas erradas e permissões por papel (aluno, tutor e admin). Sem consentimento, o backend não deixa conversar.

E se o modelo cair?
A mensagem do aluno fica salva e ele recebe um aviso amigável. O log registra só o tipo de erro, sem o conteúdo.